Internal Penetration Test Report: nexora.local

1. Executive Summary

Nexora Systems engaged our team to perform an internal penetration test of the nexora.local Active Directory environment. The objective was to evaluate the security posture of the domain and determine if a low-privileged user could escalate to Domain Administrator.

Result: The assessment was successful. By chaining together three separate vulnerabilities (Exposed Credentials, Kerberoasting, and ACL Misconfiguration), we were able to achieve full Domain Administrator access to the environment. If a real attacker were to exploit these issues, they would have complete control over the company's network, data, and users.

2. Scope and Methodology

- **Target:** nexora.local (Domain Controller DC01 at 192.168.56.10).
- **Testing Type:** Internal Red Team Simulation (Lite Build).
- **Tools Used:** Impacket, BloodHound, John the Ripper, Nmap.
- **Constraints:** The environment was isolated from the internet.

3. Attack Narrative

We began the engagement with a low-privileged foothold (lowpriv).

1. **Path A:** We enumerated SMB shares and found the IT share was accessible. Inside, we discovered a file named deployment_config.txt containing cleartext Domain Administrator credentials. We used these to obtain a shell.
2. **Path B:** We enumerated Kerberos Service Principal Names (SPNs) and identified the svc_sql account. We requested a TGS ticket and cracked it offline to reveal the password Summer2024!.
3. **Path C:** Using BloodHound, we identified that the acluser account had GenericAll permissions over the Domain Admins group. We abused this to add our user to the Domain Admins group.

4. Findings

Finding 1: Cleartext Credentials in File Share (Path A)

- **Severity:** Critical
- **Affected Asset:** \\DC01\IT\deployment_config.txt

- **Description:** A configuration file containing the Domain Administrator password was left in a world-readable share.
- **Impact:** Any authenticated user can read this file and instantly become Domain Admin.
- **Evidence:** *[Paste your Path A Screenshot here]*
- **Remediation:** Remove all cleartext passwords from files. Use Group Managed Service Accounts (gMSA) or Windows Credential Manager.

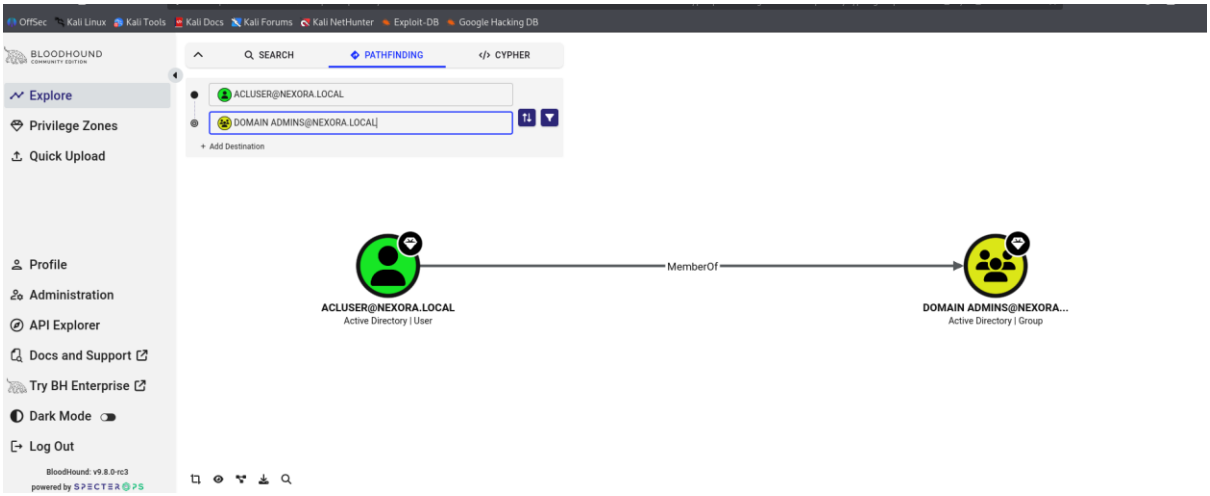
Finding 2: Kerberoastable Service Account (Path B)

- **Severity:** High
- **Affected Asset:** svc_sql user account
- **Description:** The svc_sql account has an SPN registered and uses a weak password.
- **Impact:** An attacker can request a ticket for this account and crack it offline to gain access.
- **Evidence:** *[Paste your Path B Screenshot here]*
- **Remediation:** Enforce a 25+ character password for service accounts, or migrate to gMSA.

Finding 3: Excessive ACL Permissions (Path C)

- **Severity:** Critical
- **Affected Asset:** acluser account / Domain Admins group
- **Description:** The acluser account was granted GenericAll permissions over the Domain Admins group.
- **Impact:** A low-privileged user can add themselves to Domain Admins, resulting in full domain compromise.

- **Evidence:**



- **Remediation:** Audit Active Directory ACLs regularly. Remove excessive permissions and follow the principle of least privilege.

5. MITRE ATT&CK Mapping

Technique ID	Technique Name	Path
T1552	Unsecured Credentials	Path A
T1558.003	Kerberoasting	Path B
T1098	Account Manipulation	Path C
T1078	Valid Accounts	All Paths

6. Remediation Roadmap

1. **Immediate:** Remove the deployment_config.txt file and reset the Administrator password.
2. **Short-Term:** Change the svc_sql password to a strong, complex string.
3. **Long-Term:** Conduct an AD ACL audit using BloodHound and remove the GenericAll permission from acluser.